A person that Regulate something

Topic No 21: Role Of A Regulator

تباہ کن نتائج

- Cyber attack can have devastating consequences causing financial loss and disruption of cr infrastructure
- Cyber security has become a key risk factor putting under threat not only consumer rights protection also viability and health of the industry itself
- A **cybersecurity regulation** comprises directives that safeguard information technology and comp systems with the purpose of forcing companies and organizations to protect their systems information from cyber-attacks (Wikipedia)
- Industry regulators including banking regulators have taken notice of the risk from cybersecurity have either begun or are planning to begin to include cybersecurity as an aspect of regula examinations (Wikipedia)
- **Role Of Regulator In Cyber Security:**

– Regulations, guidelines, and audit

– Engagement of key stakeholders

– Technical and industry expertise

– Regional and international cooperation

- Regionally, the most well developed cyber security strategy and framework developed by Singa (ITU rank # 1), Malaysia (ITU rank # 3), and Oman (ITU rank # 4)
- **Singapore:**

– Cyber Security Agency (2015); strategy, education, outreach, eco-system development

– National Cyber Security Master Plan 2018 (created 2013)

– Cyber Security Strategy (created 2016) MCQS

- **Pakistan; Ministry of IT (MOIT):**

– National IT Policy 2016 (draft)

– Digital Pakistan Policy 2017

- **Pakistan; State Bank Of Pakistan (SBP):**

– Enterprise Technology Governance & Risk Management Framework for Financial Institutions (30 M 2017) MCQS.

- **Pakistan lacks:**

– National cyber security strategy

Scanned with CamScanner

Topic No 22: Status Of InfoSec in Pakistan

- Pakistan Electronic Crimes Act (PECA) enacted as late as 2016
- Cyber security strategy, eco-system still missing
- Research program, capacity building, standardization, & certification bodies absent
- Condition of InfoSec in industry largely dismal

	Cybercriminal legislation	Cybersecurity legislation	Cybersecurity training	**LEGAL MEASURES**	National CERT/CIRT/CSIRT	Government CERT/CIRT/CSIRT	Sectoral CERT/CIRT/CSIRT	Standards for organizations	Standards for professionals	Child online protection	**TECHNICAL MEASURES**	Strategy	Responsible agency	Cybersecurity metrics	**ORGANIZATIONAL MEASURES**	Standardization bodies	Cybersecurity good practices	R&D programmes	Public awareness campaigns	Professional training courses	Education programmes	Incentive mechanisms	Home-grown industry	**CAPACITY BUILDING**	Bilateral agreements	Multilateral agreements	International participation	Public-private partnerships	Interagency partnerships	**COOPERATION**	**GCI**
Pakistan	●	○	○	○	●	●	●	●	●	○	○	○	○	○	○	●	●	●	●	●	○	○	●	●	○	●	●	●	●	●	○

Global Cyber Security Index 2017 (ITU): MCQs. ITU → International Telecommunication Union.

Pakistan ranked 67th with a score of 0.44/1

Bangladesh ranked 53rd with a score of 0.524/1

India ranked 23rd with a score of 0.683/1

- **Pakistan cyber security posture (industry):**
  - Superficial security
  - Reactive
  - Emphasis on governance
  - Security hardening of IT assets largely absent
  - Industry has been in denial for last decade
- **Reasons for poor security posture:**
  - Archaic digitalization and commerce
  - Perception that Pakistan is immune

Scanned with CamScanner

Topic No 23: Solution For InfoSec Improvement (PK)

- Generally, Pakistan Information Security is one generation behind IT deployment
- Four-layer security transformation model provides the correct sequence and fo organizational security gaps

1. Security Hardening; Security controls on IT assets & process
2. Vulnerability Management; patching
3. Security Engineering; More complex security design & solutions
4. Security Governance; Managing the information security program

- **Solution for strong security posture:**
  - Management commitment (Board)
  - 4 layer transformation model as security program
  - Allocation of resources
  - Periodic reviews for assessing progress
- **Don't repeat the same mistakes:**
  - Too much governance without the underlying security hardening
  - Reactive rather than intrinsic

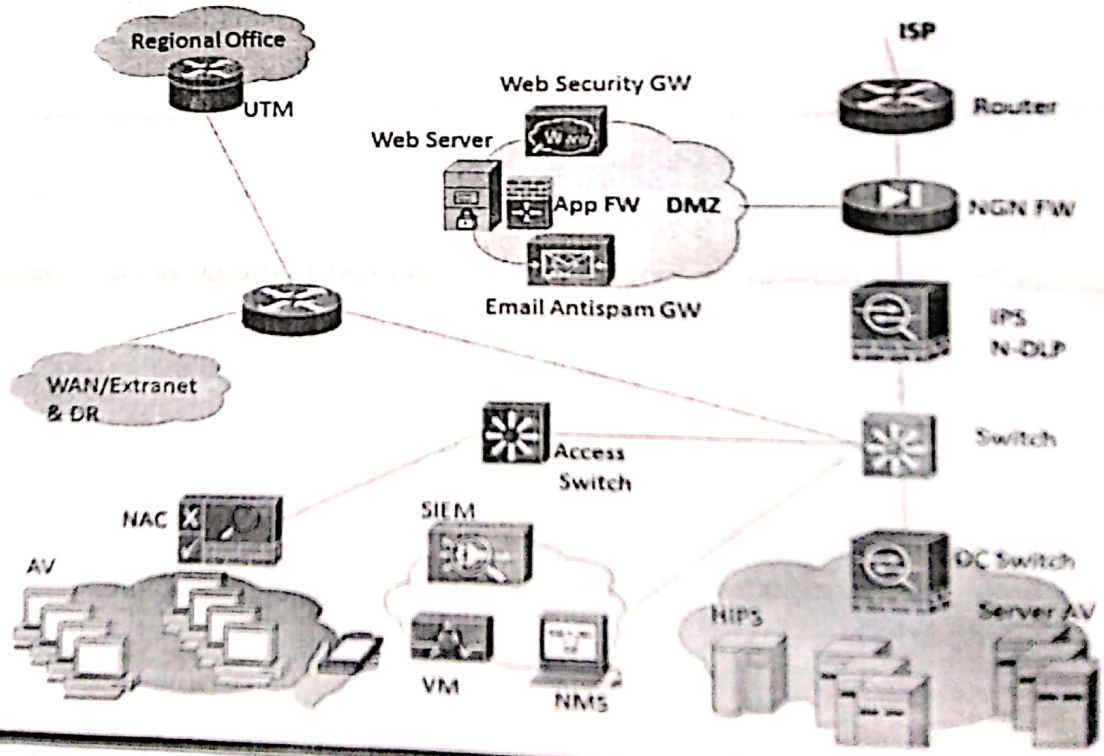
Scanned with CamScanner

- Mobile device - MDM

Topic No 25: Major Components: Enterprise IT Network

JMP 4 MCQs + Short.

- **Edge router**
  - WAN interfaces
  - Edge filtering (access lists)
  - DDOS protection
- **NGN FW** → Next Generation Firewall
  Capable of APT attack prevention, malware filtering, web security, email security, applica
  bandwidth filtering



Scanned with CamScanner

Demilitarized zone (seperate LAN from other untrusted networks).

- **DMZ:**
  - Security zone with placement of published web server, web & email security GWs, app security GW
- **IPS:** → Intrusion prevention system
  - Intrusion prevention (signature based)
  - May be feature in NGN-FW
- **Distribution switch**
  - Connectivity to access switches, external exit point (WAN), and DC switch
- **Data center switch & FW** Firewall.
  - Data center filtering (malware & access-lists)
- **Access switch**
  - User connectivity
  - Switchport security & access switch security
- **NAC** abbrevation
  - Network admission control (IEEE802.1X)
- **SIEM** → Security Information and Event Management.
  - Logging & dashboard for events, root cause analysis, event correlation
- **Vulnerability Manager**
  - Vulnerability scanning and asset tracking
- **System AV** Antivirus.
  - Signature based malware prevention
- **Server HIPS**

  IPS features for servers, also file integrity checkin
- **UTM** →
  - Multi-featured NGN FW device
- **Mobile device – MDM** Mobile device management.
  - Security features for mobile devices

Definition of IPS (network security / threat prevention technology that examines network traffic flows to detect & protect vulnerability exploit)

Topic No 26: OSI Security Architecture

- ITU-T X.800, Security Architecture For OSI ('91) MCQs.
- Defines a technique for defining security requirements, and characterizes the approaches to satisfy those requirements
- Defines security attack, mechanism, and service
- Security attack: action that compromises the security of information owned by an organization (or person)
  - Passive: aims to learn or make use of system information only
  - Active: attempts to alter system resources/operation

MCQs ✗ Short

- Security service is a service that ensures adequate security of the system or data transfer

Scanned with CamScanner

- Authentication
- Access control
- Data confidentiality
- Data integrity
- Non-repudiation
- Availability

Security Services (X.800)

- **Authentication** - assurance that communicating entity is the one claimed
  - have both peer-entity & data origin authentication
- **Access Control** - prevention of the unauthorized use of a resource
- **Data Confidentiality** –protection of data from unauthorized disclosure
- **Data Integrity** - assurance that data received is as sent by an authorized entity
- **Non-Repudiation** - protection against denial by one of the parties in a communication
- **Availability** – resource accessible/usable

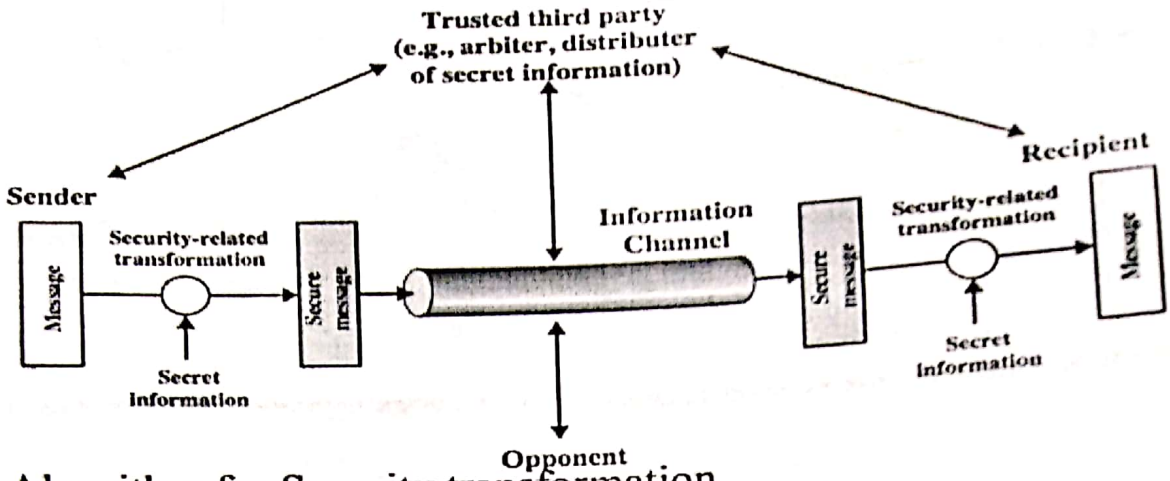
- **Security mechanism:**
  - Feature designed to detect, prevent, or recover from a security attack
  - Cryptography underlies many of the mechanisms

Services and Mechanisms Relation

Service	Mechanism						
	Enciph-erment	Digital signature	Access control	Data integrity	Authenti-cation exchange	Traffic padding	Routin contr
Peer entity authentication	Y	Y			Y		
Data origin authentication	Y	Y					
Access control			Y				
Confidentiality	Y						
Traffic flow confidentiality	Y						Y
Data integrity	Y	Y				Y	Y
Nonrepudiation		Y		Y			
Availability				Y			
				Y	Y		

Scanned with CamScanner

Model for Network Security

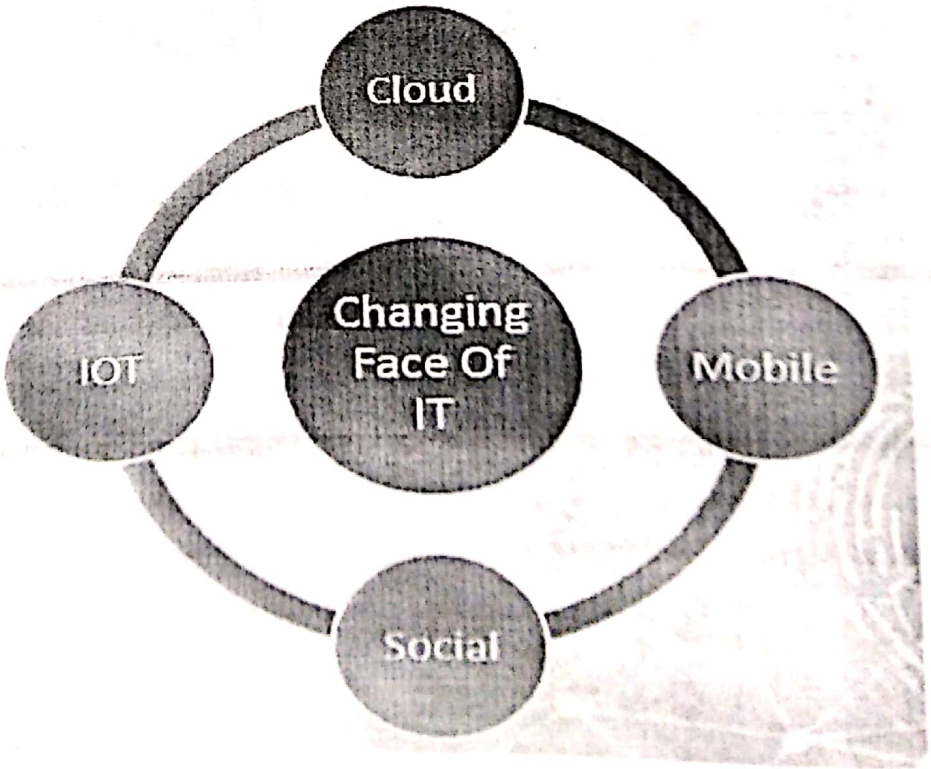


1. Algorithm for Security transformation
2. Secret key generation
3. Distributed and share secret information
4. Protocol for sharing secret information

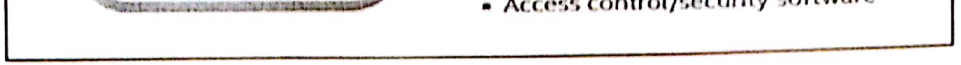
- ITU-T X.800, Security Architecture For OSI is dated from 1991

Topic No 27: New IT Frontiers: Cloud, Mobile, Social, IOT

- IT dynamics are changing the way we communicate, work, and live
- These disruptive new IT frontiers have significant security consequences



Scanned with CamScanner



Topic No 28: Virtualization Environment Security

- Cloud Security Alliance: "Best Practices For Mitigating Risks In Virtual Environments" (PDF)
- **Virtualization security classified into three areas:** VM → Virtual Machine
  - Architectural
  - Hypervisor software
  - Configuration

1. VM Sprawl → that occurs when the number of virtual machine (VMs) on a network reaches a point where administrators can no longer manage them effectively.
2. Sensitive data within VM
3. Security of offline and dormant VMs
4. Security of Pre-configured (Golden Image) VMs
5. Lack of visibility into virtual networks

• Virtualization Sprawl is also referred to as virtual machine sprawl.

- **Risk # 1 (VM Sprawl)** MCQs: VM Sprawl MCQs Impact
  - Impact: VMs can be created quickly, self-provisioned, or moved between physical servers, avoiding conventional change management process
  - Proliferation of VMs causing performance and security risks

Scanned with CamScanner

- **Controls:** Policies, procedures and governance of VM lifecycle management
- Control creation, storage and use of VM images with a formal change management process
- Discover VMs & apply security controls
- **Controls:** keep a small number of identified, good and patched images of a guest operati system separately for fast recovery & restoration of systems

- **Risk # 2 (Sensitive Data Within a VM)**
  - **Impact:** VM images and snapshots can be copied easily via USB or console of hypervi installed elsewhere
  - **Controls:** Encrypt data stored on virtual and cloud servers
  - Policies to restrict storage of VM images and snapshots
  - Image change management process with approvals
  - Logging & monitoring

Scanned with CamScanner